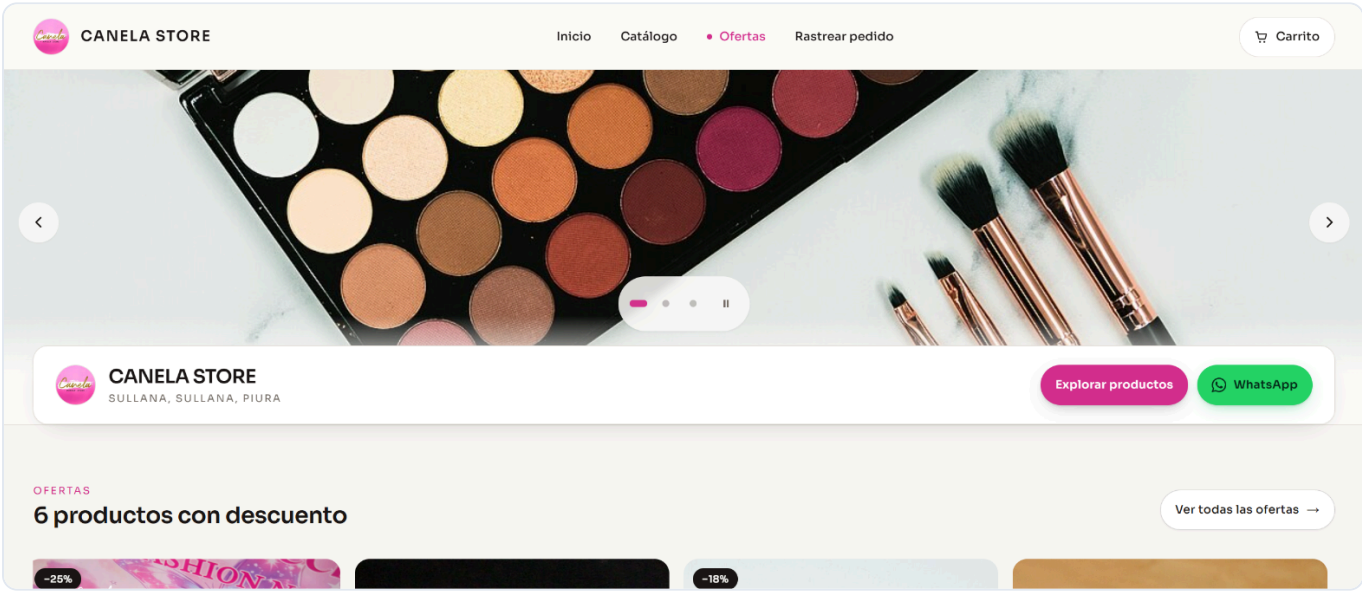
CASO DE ESTUDIO · COMERCIO ELECTRÓNICO PARA MYPES · 2026

Canela Store: tienda online y punto de venta sobre una plataforma multi-tienda

Plataforma tipo «Kyte» hecha a medida: catálogo con variantes, carrito y compra sin crear cuenta, pagos por Yape o Plin que la dueña confirma, punto de venta en mostrador, inventario que baja solo y reportes de cuánto se ganó. En producción en **tiendas.bjota.online**.

Next.js 15 · Express · TypeScript · PostgreSQL 16 · Prisma · RLS · Docker · Pruebas automáticas



AUTOR
Bryan Jeremy Espinoza Herrera
BJOTA Systems · Perú

CLIENTA PILOTO
Canela Store
maquillaje y regalos · Sullana, Piura

DESARROLLO
Ago. – oct. 2026
366 commits

01 Resumen

Canela Store es una tienda de maquillaje y regalos que vendía por WhatsApp e Instagram y llevaba el stock en una app de terceros que no lo descontaba sola cuando entraba un pedido. Construí una **plataforma multi-tienda** (varias tiendas en un solo sistema, cada una con sus datos) donde Canela tiene su propia tienda online y un panel para vender en mostrador, confirmar pagos, controlar inventario y ver cuánto ganó. La dueña vio la demo y pidió seis mejoras; las seis se implementaron.

5,600+
pruebas automáticas (API y web)

83
cambios ordenados a la base de datos

366
commits en 7 semanas

6/6
pedidos de la clienta implementados

02 El problema

Ventas solo por chat

Cada venta era una conversación: fotos, precios y datos de envío a mano. Sin catálogo propio para compartir.

Stock que no se actualizaba

La app que usaba no descontaba el stock al entrar un pedido online: se vendía lo que ya no había.

Pagos por Yape difíciles de controlar

Constancias sueltas en el chat, sin saber qué pedido estaba pagado y cuál no.

No se sabía cuánto se ganaba

Sin costo por producto ni gastos registrados, no había utilidad real por mes.

03 La solución

Tienda online propia

Catálogo con variantes de tono, ofertas, carrito y compra en 3 pasos. El cliente sigue su pedido sin crear cuenta.

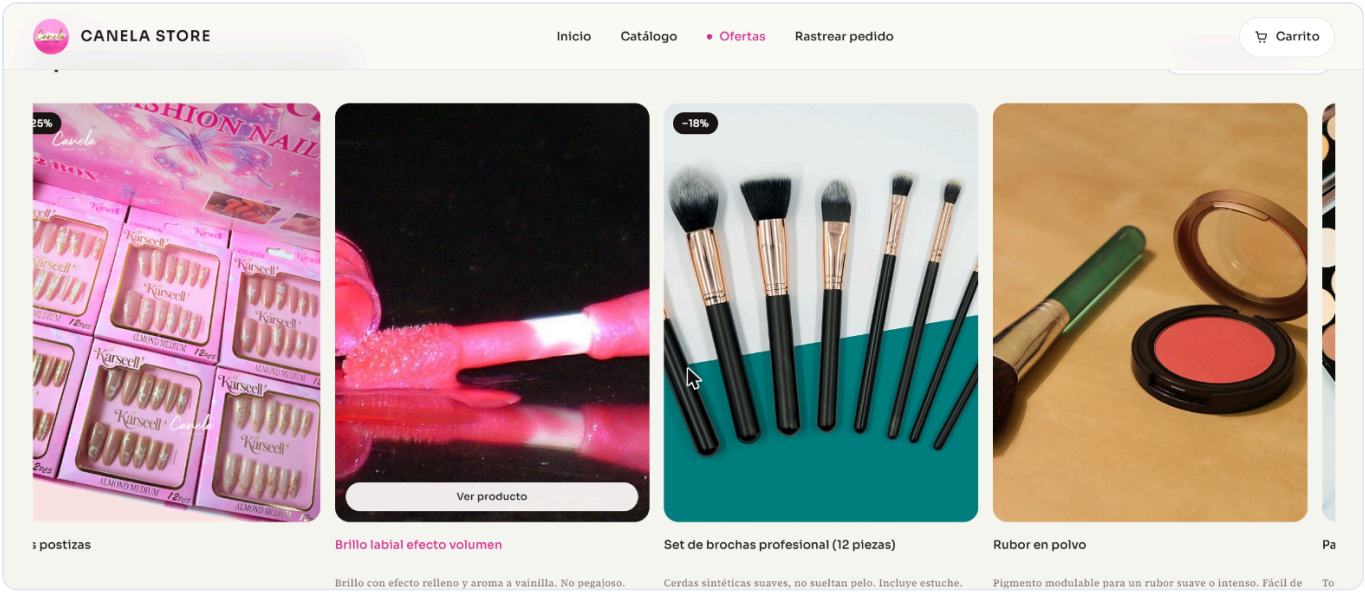
Pedidos y pagos ordenados

El cliente adjunta su constancia de Yape o Plin; la dueña la confirma y el pedido avanza (pagado, enviado, entregado).

Mostrador, stock y utilidad

Punto de venta para la tienda física, inventario que baja solo y calcula el costo real de cada producto, y reportes de ganancia.

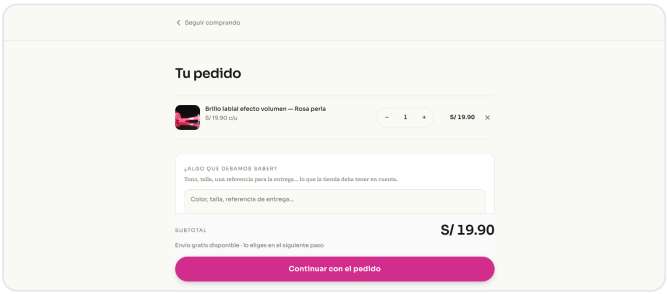
04 La tienda online (en producción)



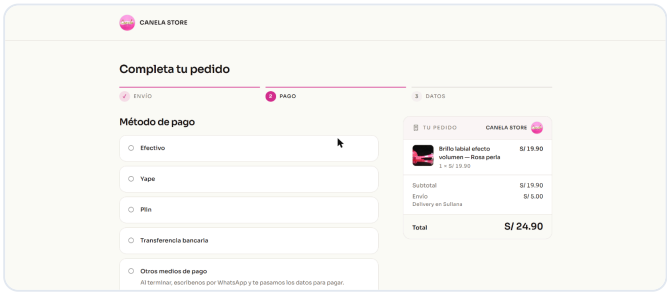
Ofertas con descuento automático en el precio.



Ficha de producto con galería y variantes de tono.

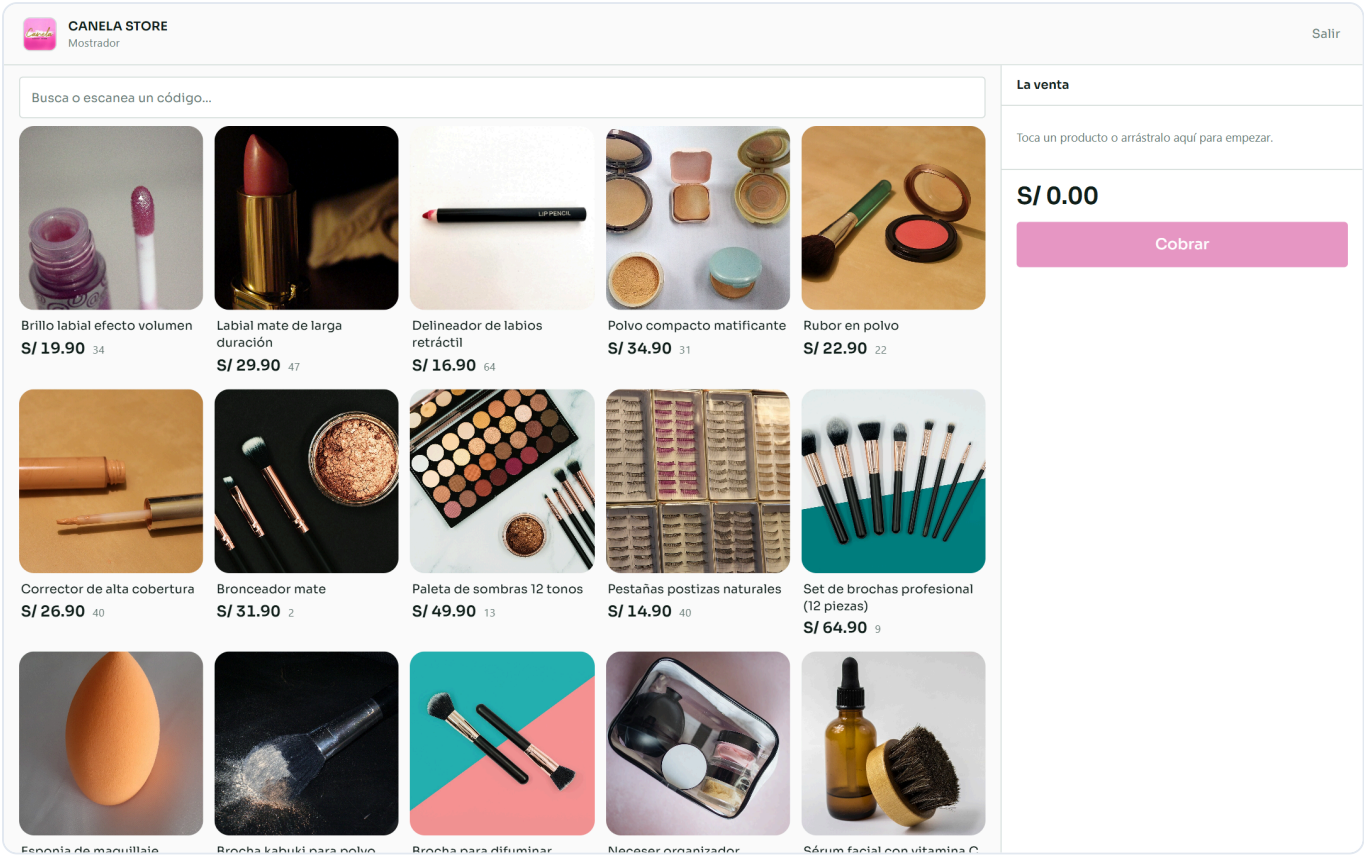


Carrito guardado en el navegador del cliente.

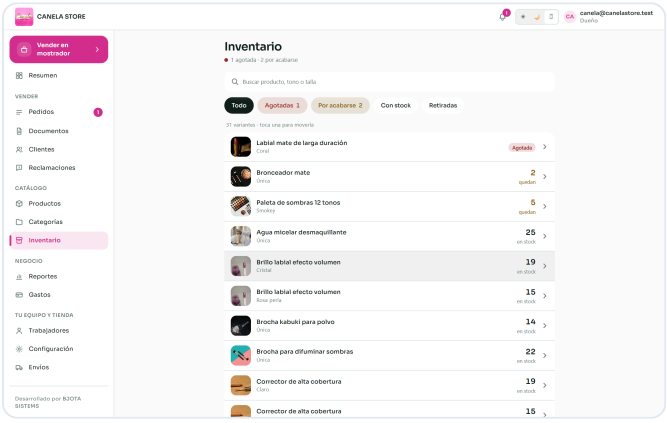


Compra en 3 pasos: envío, pago (efectivo, Yape, Plin, transferencia u otros) y datos.

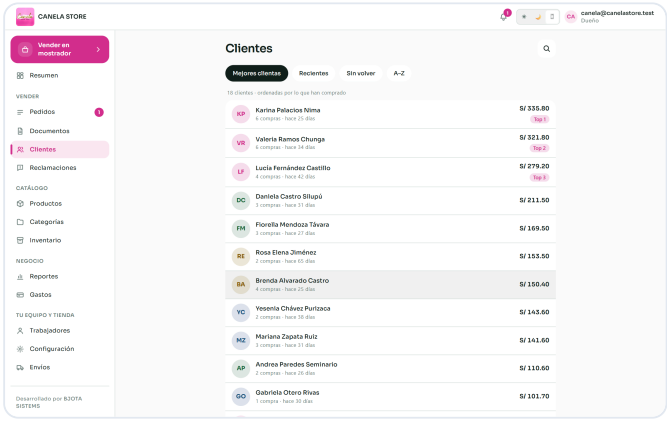
05 El panel de la dueña



Mostrador (POS): vender en la tienda física, pagar con dos métodos a la vez y calcular el vuelto; el stock baja al instante.

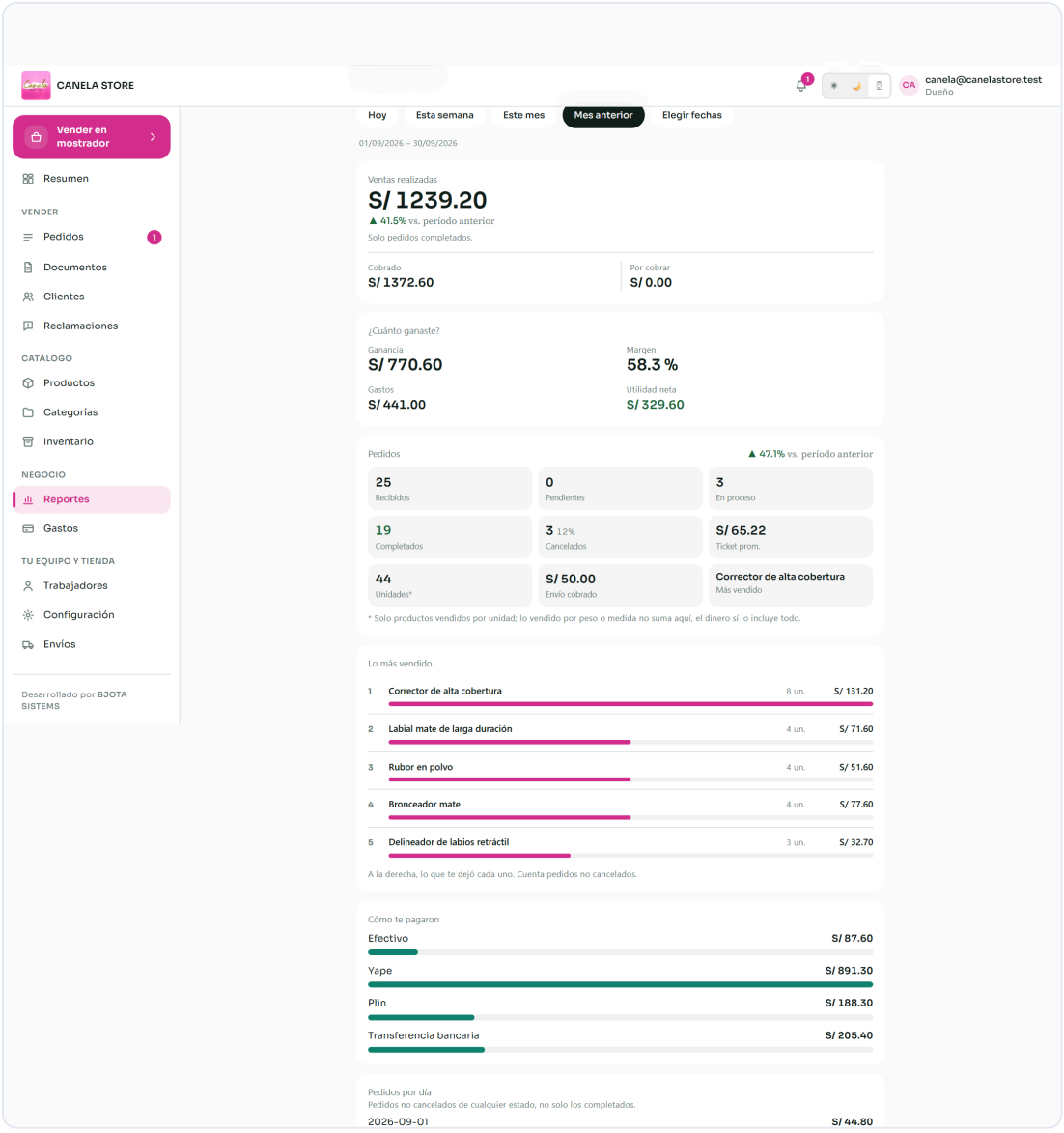


Inventario con alertas de agotado y por acabarse.



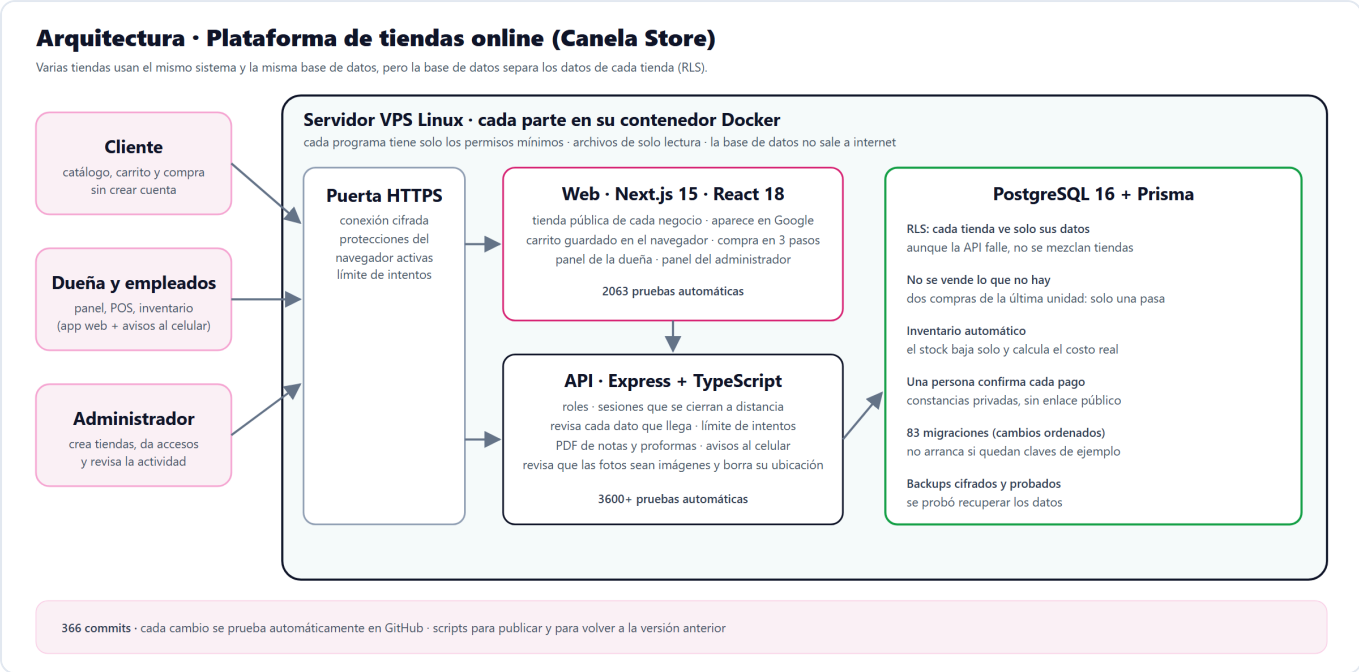
Clientes ordenados por lo que más compran.

06 Reportes: cuánto se ganó



Reporte de septiembre (datos de demostración): ventas, ganancia y margen, utilidad después de gastos, productos más vendidos y cobros por método.

07 Cómo está armado



La **web** (Next.js) es lo que ven el cliente y la dueña. La **API** (Express) es el programa del servidor que recibe los pedidos y aplica las reglas. Los datos se guardan en **PostgreSQL**, y uso **Prisma** para trabajar con la base de datos desde el código. Todo corre en **Docker** (cada parte en su propio contenedor) dentro de un **VPS**, un servidor Linux alquilado.

Decisiones clave

Decisión	Por qué
Cada tienda ve solo sus datos	Uso RLS: la propia base de datos separa los datos de cada tienda. Así, aunque la API tenga un error, una tienda no puede ver los pedidos ni los clientes de otra.
No se vende lo que no hay	La compra online, la venta en mostrador y la proforma siguen las mismas reglas. Si dos clientes compran la última unidad al mismo tiempo, solo uno lo logra.
Una persona confirma cada pago	No hay pasarela de pago: el cliente avisa que pagó y adjunta su constancia. La constancia se guarda en un lugar privado; nadie puede abrirla con un enlace público. Solo quien tiene permiso puede confirmar pagos.
Sesiones que se pueden cerrar	Si un empleado pierde el celular, la dueña puede cerrar su sesión a distancia. Los enlaces de acceso solo sirven una vez.
Claves que no se olvidan	El sistema no arranca si alguien dejó las contraseñas de ejemplo sin cambiar.
Permisos mínimos	Cada programa del servidor tiene solo los permisos que necesita y no puede modificar sus propios archivos. La base de datos no es accesible desde internet.
Notas de venta, no boletas	Los PDF son notas internas y proformas; no se presentan como comprobantes SUNAT.

08 Seguridad probada

- **Revisión de seguridad** de la primera etapa, sin fallas graves.
- **Probé ataques comunes en una copia del sistema:** meter código malicioso en un formulario (XSS), por ejemplo en el nombre de una tienda; intentar burlar el límite de intentos haciéndose pasar por otra dirección IP; y revisar que todo vaya por HTTPS (conexión cifrada) con las protecciones del navegador activas.
- **Límite de intentos** en el inicio de sesión y en los pedidos públicos, para frenar abusos. La opción "olvidé mi contraseña" también está protegida.
- **Fotos:** se revisa que de verdad sean imágenes y se borran datos ocultos, como la ubicación del celular.
- **Backups cifrados y probados:** hice una prueba real de recuperar los datos desde un backup y la dejé documentada.
- **CI:** cada cambio se prueba automáticamente en GitHub.

09 Lo que pidió la clienta

Tras ver la demo, la dueña de Canela pidió seis cambios. Todos quedaron implementados:

- Modo mostrador (POS) para vender en la tienda física.
- Compra que se adapta al tipo de envío (recojo, delivery local, agencia a todo el Perú).
- Método de pago "Otros / a coordinar" por WhatsApp.
- Editar pedidos ya creados.
- Nota de venta en PDF.
- Precio por mayor según la cantidad.

10 Resultados

- **En producción** en `tiendas.bjota.online`, con la tienda de Canela cargada como demo para la clienta.
- **Calidad:** 2063 pruebas automáticas de la web verificadas el 17/10/2026 y 3622 de la API en la última corrida completa registrada (más 7 omitidas).
- **Pendientes declarados:** correo transaccional, backups fuera del servidor, pasarela de pago y facturación electrónica SUNAT.

11 Lo que aprendí

- **Escuchar a la clienta cambia el producto.** Lo que más valoró (vender en mostrador y la compra según el envío) no estaba en el plan inicial.
- **Cuando todos compran a la vez.** Hay que cuidar que dos ventas al mismo tiempo no se lleven el mismo producto. El cliente no lo ve, pero para el negocio es clave.
- **Atacar mi propio sistema.** Probar ataques como XSS, intentar saltarme el límite de intentos y recuperar un backup antes de que lo haga otro es lo que me interesa de la ciberseguridad.
- **IA como herramienta con método.** Desarrollé con asistentes de IA, pero con método: un plan por etapa, pruebas y revisión de cada avance.

12 Mi rol

Proyecto propio completo: conversé con la dueña de Canela para entender qué necesitaba, diseñé la base de datos y cómo se conectan las partes, desarrollé la API y la web con apoyo de asistentes de IA, escribí las pruebas, protegí el servidor y publiqué el sistema, e implementé los cambios que pidió la clienta.

La tienda pública se capturó en producción sin enviar pedidos. El panel proviene de una copia local del sistema con datos de demostración; fotos de productos de Wikimedia Commons con licencia libre. No se publican el código fuente, datos de clientes reales ni detalles internos del servidor.

Bryan Jeremy Espinoza Herrera · BJOTA Systems · 2026